

Trabalho – segunda parte

Título: Análise e Remediação de Código através de SAST

Descrição: A segunda parte do trabalho da disciplina de Desenvolvimento de Software Seguro tem por objetivo desenvolver as competências práticas na identificação, análise e correção de vulnerabilidades em software, com recurso a ferramentas de análise estática de código (SAST).

Os alunos deverão escolher uma aplicação ou projeto com vulnerabilidades conhecidas (como apresentado durante as aulas da disciplina), e fazerem um scan de SAST (com ferramenta à escolha) antes e depois de aplicarem correções para pelo menos 3 tipos de vulnerabilidades diferentes. O processo deverá ser descrito num pequeno relatório (não mais de 4 páginas) e deverá ser feita uma apresentação do trabalho realizado.

Objetivos de aprendizagem:

1. Familiarizarem-se com a utilização de ferramentas de SAST na deteção de vulnerabilidades em código fonte.
2. Analisar e entender a natureza das vulnerabilidades de software.
3. Desenvolver capacidades práticas na identificação e correção de vulnerabilidades em software.

Formato do trabalho:

- **Geral**
 - **Tipo de trabalho:**
 - Grupo (preferencialmente 2 elementos, máximo 3 elementos)
 - Prático (com relatório)
 - Apresentação
 - **Idioma:**
 - **Relatório:** Preferencialmente Inglês.
 - **Apresentação:** Português.
 - **Identificação do grupo:** O relatório deverá identificar os elementos do grupo.
 - **Submissão e formato:** Os trabalhos devem ser submetidos através do Moodle num Zip contendo todos os materiais do trabalho, relatório e apresentação.
- **Trabalho Prático e Relatório**
 - **Escolha do Projeto:** Selecionar uma aplicação ou projeto vulnerável adequado ao uso de ferramentas SAST.
 - **Tecnologia e Linguagem de Programação:** Identificação da tecnologia e a linguagem de programação utilizadas no projeto.
 - **Processo de Scan:** Realizar dois scans utilizando uma ferramenta de SAST da vossa preferência:
 - Um scan do projeto na versão original.
 - Um scan após as correções aplicadas.
 - **Análise de Vulnerabilidades:** Identificar, pelo menos, três vulnerabilidades distintas no código (por aluno).
 - **Correção de Vulnerabilidades:** Corrigir o código dos resultados escolhidos para análise e discutir as correções aplicadas.
 - **Relatório:**
 - Máximo de 4 páginas.
 - Identificação dos elementos do grupo.

- Enquadramento e descrição do processo de seleção do projeto, scan, análise e correção das vulnerabilidades.
- Ferramenta SAST utilizada, número de potenciais vulnerabilidades identificadas, identificação das vulnerabilidades escolhidas para análise e para serem corrigidas.
- Resultados dos dois scans.
- **Apresentação**
 - **Contexto do Projeto:** Descrever o projeto, a tecnologia e a linguagem de programação, e o porquê da escolha para este exercício.
 - **Resultados dos Scans:** Apresentar os resultados identificados nos dois scans. Com focos nos resultados que foram analisados.
 - **Análise e Correção:** A apresentação deve focar nas vulnerabilidades identificadas e explicar as correções aplicadas.
 - **Duração:** 20/25 minutos, seguidos de 5/10 minutos de perguntas e respostas.
 - Todos os elementos do grupo devem apresentar.

CrITÉrios de Avaliação:

- Compreensão dos materiais expostos e analisados – coerência e clareza na estrutura e exposição dos conteúdos.
- Clareza e detalhe no relatório e na apresentação.
- Qualidade técnica na identificação e correção de vulnerabilidades.
- Familiarização com a utilização da ferramenta SAST e na explicação dos resultados.

Notas sobre plágio: Os trabalhos submetidos serão verificados quanto à sua originalidade. Qualquer forma de plágio resultará numa penalização severa para a nota final do trabalho.